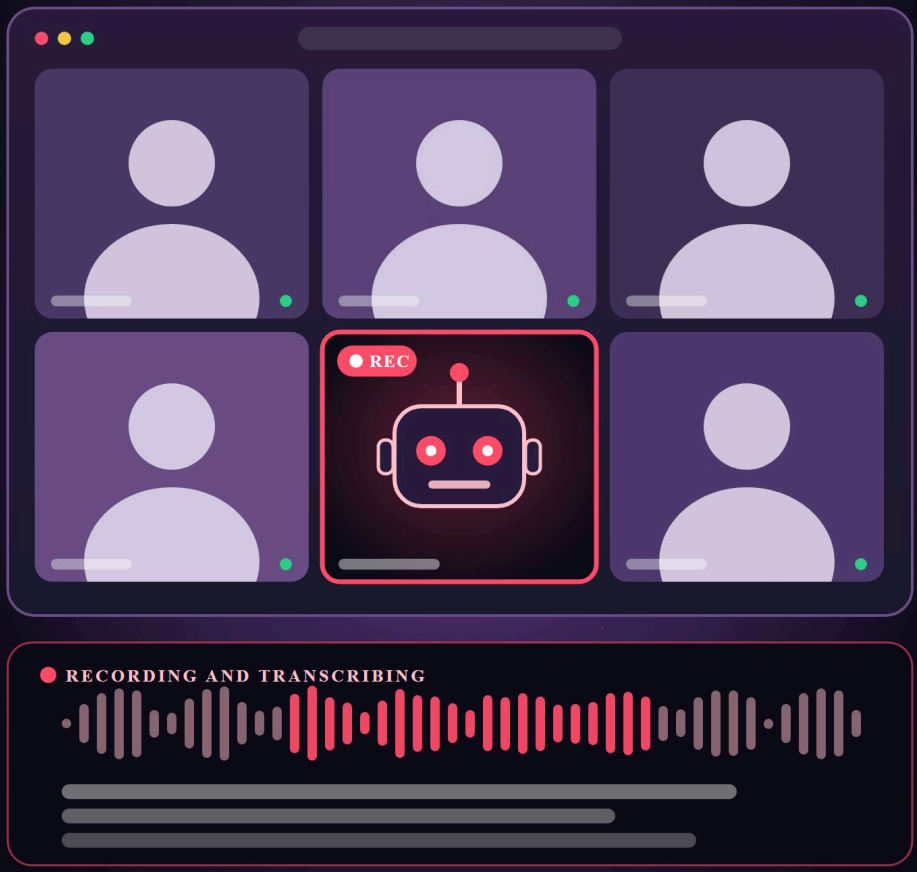
AI PRIVACY AND GOVERNANCE

THE MEETING BOT IS IN THE ROOM



A Practical Privacy and Security Guide to
AI Recording, Transcription and Workplace Notes

RECORDING · TRANSCRIPTION · GDPR · WORKPLACE

ZIRLANDIA MILKOVIC

AI PRIVACY AND GOVERNANCE

THE MEETING BOT IS IN THE ROOM

A Practical Privacy and Security Guide to AI Recording, Transcription and Workplace Notes

ZIRLANDIA MILKOVIC

The Meeting Bot Is in the Room
A Practical Privacy and Security Guide to AI Recording, Transcription and Workplace Notes

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced without written permission, except for brief quotations in reviews.

First edition, 2026. Research cut-off: 13 November 2026. British English. Companion resource: GDPRGard.eu.

This book is practical guidance, not legal, security or data-protection advice. All examples, businesses and people in worked scenarios are fictional. Laws, court cases and vendor settings reflect the research cut-off date and should be checked against the current legal texts, regulator guidance and vendor documentation.

Contents

START HERE

Educational Disclaimer 4
Introduction: The Guest Who Was Not on the Invitation 4
Who This Book Is For 6
How to Use This Book 6
The Ten-Minute Meeting-Bot Check 7

CHAPTERS

1. How AI Meeting Assistants Capture Conversations 9
2. Participant Notices and Recording Rules 15
3. Lawful Basis and Transparency Under the GDPR 20
4. Employee Privacy and Workplace Monitoring 25
5. Vendor Contracts and AI Model Training 31
6. International Transfers and Subprocessors 36
7. Access Restrictions and Deletion Procedures 40
8. A Responsible AI Meeting Policy 46

CLOSING

Conclusion: Let the Room Know 51

APPENDICES

Appendix A: AI Meeting-Assistant Inventory 52
Appendix B: Meeting-Sensitivity Matrix 54
Appendix C: Vendor Due-Diligence Questionnaire 56
Appendix D: Participant Notice Wording 58
Appendix E: Responsible AI Meeting Policy (One-Page Template) 60
Appendix F: Retention, Deletion Log and 30-Day Tracker 62

BACK MATTER

Glossary 64
A Note on GDPRGard.eu 65
About the Author 66
Notes and Sources 67

Educational Disclaimer

This book is practical, educational guidance for small business owners, HR managers, consultants, data-protection officers and remote teams who use, or are being asked to approve, AI meeting assistants: tools that record, transcribe, summarise and analyse conversations. It is not legal, employment, data-protection or regulatory advice, and it does not create a professional relationship between the author and the reader.

Recording and monitoring law is local, technical and changing. Whether a particular recording is lawful can depend on the country, the US state, the participants, the purpose, the employment relationship, any works-council agreement and the exact settings of the tool. Court cases described in this book are allegations unless a court has decided them, and the author has not read the full court documents. Several regulatory points come from secondary summaries rather than from the regulators' own texts. The notes at the back say which, and list what could not be verified. Before you roll out, ban or promise anything, read the current rules, your regulator's guidance and your vendor's own documentation, and take advice where the stakes are high: HR investigations, legal matters, health information, works councils and cross-border workforces in particular.

Following the steps here can make your use of meeting assistants more transparent, more secure and easier to defend. It cannot guarantee that a regulator, a court, a client or a works council will agree with every decision.

Every business, person and incident in a worked example is **fictional** and labelled as such. Product names appear only to describe how a category of tool works; no vendor is accused of anything by this book, and vendor settings change often.

Introduction: The Guest Who Was Not on the Invitation

Ines runs Northlight Advisory, a nine-person consultancy that helps small manufacturers prepare for audits. On a Tuesday in March she joined a video call with a prospective client, the finance director of a family firm. Four minutes in, a participant named "Notes Assistant" appeared in the list. Nobody had invited it. Nobody admitted adding it. The finance director, mid-sentence about a pending dispute with a supplier, stopped and asked, "Who is that?"

It turned out to belong to a junior colleague of Ines, who had connected a free note-taking tool to his calendar months earlier. It joined every meeting he was invited to, whether or not he attended. It recorded, transcribed and, ten minutes after the call, emailed a tidy summary to every participant, including the finance director's personal address, with a link to a searchable page containing the whole transcript. The summary included the supplier dispute, an offhand remark about the client's chairman, and the price Ines had quietly intended to quote.

Nothing malicious happened. Everyone who touched that tool was trying to be helpful. And yet Ines lost the client, spent a week finding out where the transcripts had gone, discovered that the vendor's terms permitted using content to improve its models, and realised she could not honestly say how many meetings had been captured, who could read them, or how to make them disappear.

That is the problem this book exists to solve. AI meeting assistants are not a fringe product. They are built into the video platforms you already pay for, they are offered as free add-ons by dozens of start-ups, and they are adopted one employee at a time without anyone deciding to adopt them. Commentators have started to call the governance challenge "the second wave" of workplace AI: first came policies and committees about whether to allow generative AI at all, and now comes the harder, daily question of how people actually use tools like these.[1] Law firms have begun warning clients that the same tools can create searchable records of sensitive conversations, expose confidential information, and raise GDPR, vendor-contract and employee-monitoring issues all at once.[2] And in the United States, a proposed class action filed in August 2025 alleges that one popular notetaker recorded people who never agreed to it and used recordings to train its models. Those are allegations, not findings, but they show how quickly an ordinary productivity tool can become a legal exhibit.[3]

This book is the practical answer. It will not tell you to ban meeting assistants; many teams get real value from them, particularly people who are neurodivergent, who work in a second language, or who would

otherwise spend the afternoon typing up minutes. It will tell you how to use them **on purpose**: what these tools actually capture, what you must tell people, which legal basis you can credibly rely on, where employee privacy draws the line, what to demand from a vendor, where the data travels, who gets to see it and when it must disappear, and how to put all of that into a one-page policy that people will read.

You will not need to be technical or a lawyer. You will need to be willing to look, once, at the settings you already have.

Who This Book Is For

This book is written for the people who end up owning the question "are we allowed to use this?" in organisations too small to have a dedicated privacy team:

- **Small business owners and managers** whose teams are already running AI notetakers, with or without permission.
- **HR managers** who are asked whether recorded one-to-ones, interviews and disciplinary meetings are acceptable, and who hold the most sensitive conversations in the company.
- **Consultants, advisers and agencies** whose clients are uneasy about a bot joining the call and whose own confidentiality duties are on the line.
- **Data-protection officers and privacy leads** who need a defensible, plain-language framework to put in front of management, vendors and works councils.
- **Remote and hybrid teams** who live on video calls and have, in effect, built a second archive of company knowledge without designing it.

It is written from a European, GDPR-first point of view, because that is where most of the strictest duties sit, with plain notes where United States recording laws change the picture. It is not written for vendors, and it is not a legal treatise. It will tell you what to ask your lawyer and in what order.

How to Use This Book

The eight chapters follow the life of a recording, from the moment a bot joins to the moment its data should be gone:

1. **How AI meeting assistants capture conversations.** What the tools are, what they collect and where it goes.
2. **Participant notices and recording rules.** Telling people, getting agreement where you need it, and the host-consent trap.
3. **Lawful basis and transparency under the GDPR.** Which legal basis can carry a transcript, a summary or an analytics score.
4. **Employee privacy and workplace monitoring.** Where note-taking ends and monitoring begins.
5. **Vendor contracts and AI model training.** The terms that decide who owns, reuses and learns from your meetings.
6. **International transfers and subprocessors.** Following the data across borders and through the vendor's own suppliers.
7. **Access restrictions and deletion.** Who can read what, for how long, and how to prove it is gone.
8. **A responsible AI meeting policy.** The one-page rulebook and a thirty-day rollout.

The appendices are working documents: an assistant inventory, a meeting-sensitivity matrix, a vendor due-diligence questionnaire, participant notice wording, a policy template and a retention and deletion register. Copy them, fill them in and keep them current.

Look for the dark boxes headed **The rule**. Each states, in one sentence, the principle a chapter turns on. If you read nothing else, read those.

The Ten-Minute Meeting-Bot Check

Before the first chapter, answer these honestly. A "no" or "I don't know" is not a failure. It is the start of your to-do list.

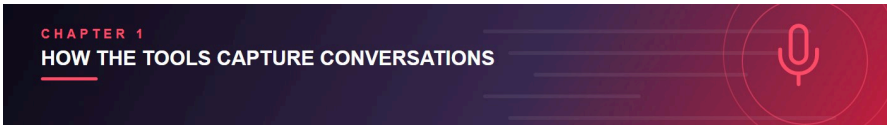
- ☐ I can name every AI meeting assistant, built-in or third-party, that anyone in my organisation uses.
- ☐ I know whether any tool joins meetings automatically through a connected calendar.
- ☐ Participants, including guests and clients, are told before a meeting is recorded or transcribed.
- ☐ I know what the vendor does with our recordings, including whether it uses them to train its models.
- ☐ We have a signed data-processing agreement with each vendor.

- ☐ I know in which countries recordings and transcripts are stored and processed.
- ☐ Summaries do not go automatically to everyone on the invitation, or to personal addresses.
- ☐ We have a written retention period, and recordings really are deleted when it ends.
- ☐ There are meetings where bots are never allowed, and everyone knows which they are.
- ☐ Staff have been told what the tools may and may not be used to measure.

Score one point for each box you can tick without hesitation. Under five means the chapters that follow will be immediately useful; start with the appendices. Between five and eight means you have the basics and will find the gaps in Chapters 5 to 7. Nine or ten means you may be ahead of most organisations; check your answers against the evidence, not your memory.

CHAPTER 1

How AI Meeting Assistants Capture Conversations

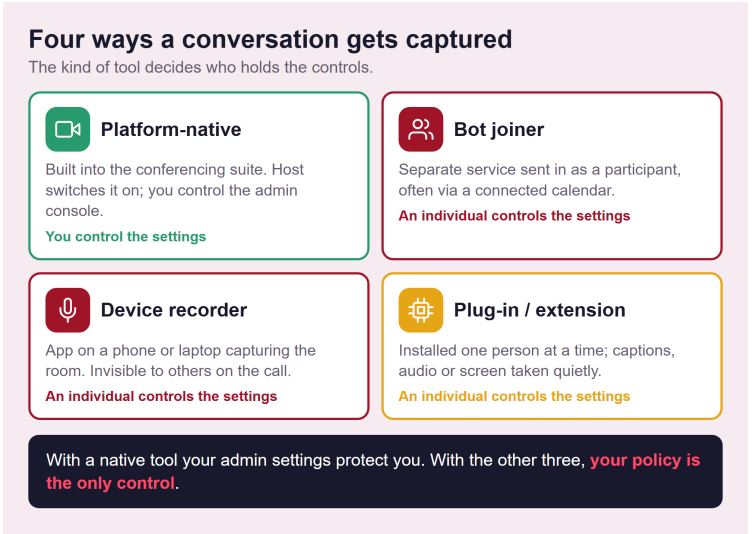


A meeting table with an unattended device: the question is never only who is in the room, but what is listening

Start with a clear picture of what you are dealing with, because "AI notetaker" covers very different things with very different risks.

An **AI meeting assistant** is software that listens to a conversation, turns speech into text, and then does something with the text: summarises it, extracts action items, labels who said what, files it, searches it, or scores it. The listening happens through the video platform, through a bot that joins as a participant, or through an app on someone's device. The "something" happens on the vendor's servers, which may belong to the vendor, to a cloud provider or to an AI model supplier behind the vendor.

Four kinds of assistant



Four ways a conversation ends up captured: native, bot, device and plug-in

Platform-native assistants. The video platform itself offers recording, transcription and AI summaries: the assistants built into the major conferencing and collaboration suites. You already have a contract with the platform, the host usually has to switch the feature on, and participants typically see a banner or prompt. These are generally the easiest to govern, because the settings sit in an admin console you control.[10]

Bot joiners. A separate service sends an automated participant into the call. It appears in the participant list under a name like "Notes Assistant", records and transcribes, and delivers a summary afterwards. The bot is often connected to a person's calendar and joins every meeting automatically. This is the category behind most surprises, because the person who connected the tool is not the person whose meeting it enters.

Device and local recorders. An app on a phone or laptop captures the room or the call audio directly, with no bot in the meeting at all. Nobody else on the call can see it. This is the hardest category to detect and, for in-person meetings, often the only one in use.

Plug-ins and browser extensions. Add-ons that sit inside a browser or a conferencing tool and quietly capture captions, audio or screen content. Because they are installed individually, they tend to escape any approval process.

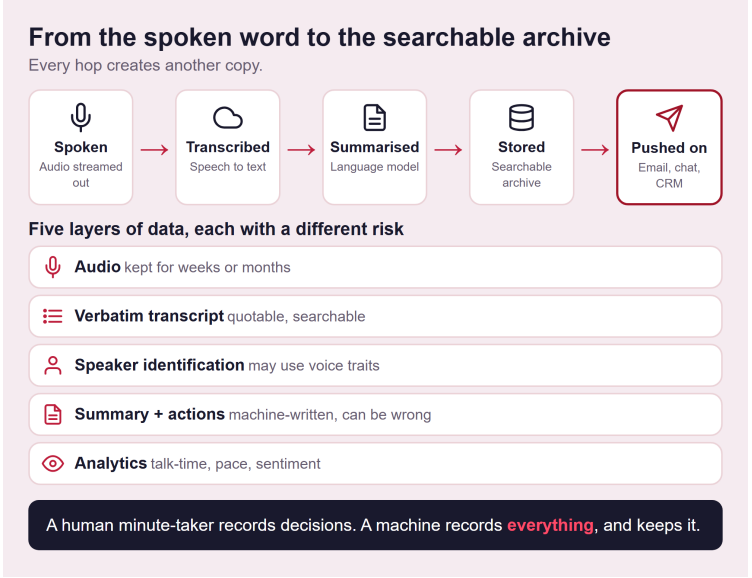
The type matters for one reason above all: it decides **who controls the settings**. With a native tool, you do. With a bot or a device, an individual employee does, and your policy is the only control you have.

What they actually capture

People tend to think of a recording. The modern assistant collects far more:

- **The audio** itself, sometimes stored for months.
- **A verbatim transcript**, with timestamps, which is searchable and quotable.
- **Speaker identification**, matching voices or names to statements. Where this uses voice characteristics rather than the participant list, it can involve biometric processing, a stricter area of data-protection law.
- **A summary and action items**, written by a language model, which can be wrong or can emphasise things nobody intended.
- **The chat, shared files and screen content**, including whatever happened to be open on the presenter's desktop.
- **Metadata**: who attended, when, how long, who spoke most.
- **Derived analytics**: talk-time ratios, filler words, pace, "engagement" or sentiment scores.

Each layer is a different kind of data with a different risk. A summary of decisions is not the same as a word-for-word transcript of a candid conversation, and neither is the same as a score of how enthusiastic someone sounded. Most of the legal and ethical questions in this book come from keeping those layers apart.



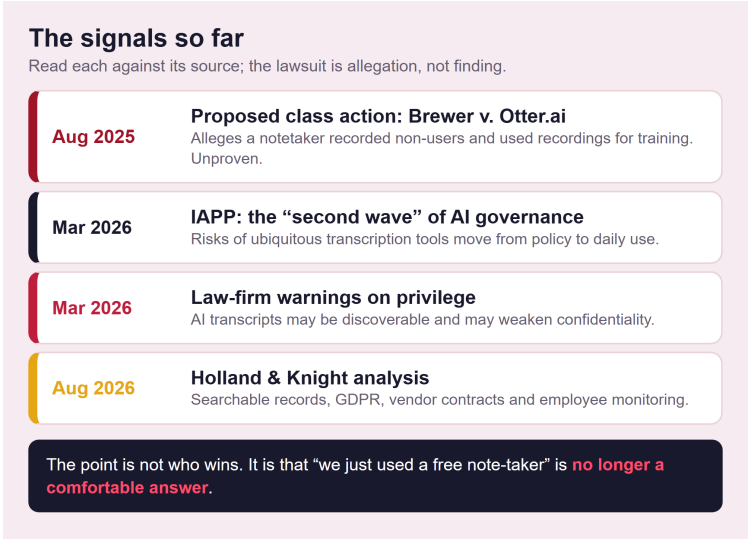
The capture pipeline: from the spoken word to a searchable archive and, sometimes, to model training

Where it goes next

Follow a single sentence. Someone says it aloud. The audio is streamed to the vendor's cloud, often in another country. A transcription model converts it to text. A language model, which may be run by a third company, writes the summary. The result is stored in the vendor's database under a user account, indexed so it can be searched, and often pushed onward: to email, to a chat channel, to a CRM, to a task tracker. Each hop creates a copy, a new place where it can be read, leaked or kept.

Three features make this different from the minutes a human used to write:

1. **Completeness.** A human minute-taker records decisions. A machine records everything, including the aside, the joke, the disclosure and the disagreement.
2. **Searchability.** A pile of paper minutes could be ignored. A searchable archive can be queried by anyone with access, in a dispute, an audit or an investigation, and some assistants advertise exactly this as a selling point.[2]
3. **Persistence by default.** A conversation used to evaporate. A recording lasts until somebody deletes it, and in many products nobody is assigned to.



A short timeline of signals: the commentary, the lawsuit and the legal alerts that put meeting assistants on the governance agenda

Why this is now a governance problem

A tool that records conversations at work sits at the intersection of four areas that most small organisations handle separately: privacy law, employment law, contract law and information security. The market signals above are not isolated. Commentators describe a "second wave" of AI governance that is about everyday use rather than headline policy; [1] law firms warn that transcripts are discoverable records and may undermine confidentiality or privilege;[2][5] and a proposed class action alleges that a non-user participant was recorded without their agreement.[3] Remember that the case is unproven and the court has made no findings. The point is not who wins. The point is that "we just used a free note-taker" is no longer a comfortable answer.

The good news is that the response is not complicated. You need to know what is in use, tell people, choose a lawful reason, set boundaries for sensitive meetings, hold the vendor to a contract, understand where the data goes, control who sees it and delete it on time. That is the sequence of this book.

> **The rule:** A meeting assistant is not a pen. It creates a record that someone will be able to search, forward and, eventually, be asked to produce. Decide on purpose, or it will be decided for you.

The shadow-assistant problem

Before you can govern the tools, you have to find them. Ask three groups, and ask without blame:

- **Everyone:** "Which tools do you use to record, transcribe or summarise meetings, including free ones and personal accounts?"
- **IT or whoever manages your accounts:** which AI apps have been granted access to calendars, email or video accounts through "Sign in with" buttons.
- **Your platforms' admin consoles:** which add-ons and integrations are installed, and which AI features are switched on by default.

People will usually tell you the truth if the answer will not get them into trouble. Record what you find in Appendix A. If you only do one thing after reading this chapter, do that.

Worked example (fictional): the calendar that never sleeps

Tomás is a project manager at a twelve-person design agency. Eighteen months ago he connected a note-taking app to his work calendar to save himself effort. It joins any video meeting that appears on his calendar. When he took parental leave, his calendar kept its recurring invitations. For six weeks the assistant attended the agency's weekly staff meeting, a client review and an informal "how are we doing" session with nobody from Tomás's side present, transcribed all of them, and emailed the summaries to a shared inbox that three contractors can read.

Nobody did anything wrong in the sense of intending harm. But the agency now holds six weeks of unreviewed transcripts, including a discussion of someone's performance, on a free account with no data-processing agreement. It cannot say what the vendor has done with them. The fix is not blame. It is an inventory, a rule that automatic joining is off unless approved, and a clear owner for deleting what exists. Each of those appears later in this book.

CHAPTER 2

Participant Notices and Recording Rules

An empty meeting room at dusk: people should always know when a room has an extra listener

The first duty you owe a person you are about to record is the simplest: tell them. The second is to understand whether telling them is **enough**, or whether you also need their agreement. The answer changes with where they are, who they are, and what you are doing with what they say.

Two separate questions

Two questions get tangled constantly, and separating them removes most of the confusion:

1. **Is it lawful to capture the audio at all?** This is mainly a matter of recording and wiretap law, which is about the act of listening and is mostly national or, in the United States, state law.
2. **Is it lawful to process the resulting personal data?** This is data-protection law, such as the GDPR, which governs what you do with the transcript, summary and analytics once they exist. Chapter 3 covers it.

You must satisfy both. A recording can be perfectly lawful to make and still processed unlawfully, or the reverse.

The recording-law landscape in brief

Do not treat any of the following as legal advice; treat it as a map showing why you cannot assume one rule fits everywhere.

One-party and all-party consent. In many places, a person who is a party to a conversation may record it without telling the others. In others, everyone on the call must agree. In the United States the rule varies by state, and a number of states require the consent of all parties, which is why a call between participants in different states can be governed by the strictest of them. Federal and state wiretap laws also use language about interception by a third party, and a recent argument is whether an AI vendor that listens to a meeting is such a third party.[4]

Europe. There is no single EU rule for recording a conversation you take part in. National criminal and civil law decides, data-protection law governs what you then do with it, and national regulators have issued their own guidance on meeting recording; Luxembourg's regulator, for example, published guidance on recording meetings in April 2026.[11] The safe working assumption in Europe is that you inform every participant in advance and have a clear lawful basis, which is also what the GDPR requires.

Work and guests. The rules often differ for employees, for external guests and for people in a different country from you. An external client on your call is not covered by your employment contract or staff policy. They are a stranger whose voice you are about to feed to a third-party vendor.

Because the strictest applicable rule is often the right one to build on, most organisations do best by adopting a single practice that satisfies the toughest case: **announce, name the tool, give a real way to object**.

The host-consent trap

This is the single most important point in the chapter. In most bot and native products, the **host** clicks "allow" or invites the bot. That is the only consent the software asks for. Everyone else simply finds themselves being recorded.

The proposed class action mentioned earlier turns on exactly this theory: that the tool asks the account holder or host for permission but does not by default ask the other participants, who never agreed to be captured or to have their words used.[3] Whatever a court decides, the principle holds. **The host's agreement is not the participants'**

agreement. The meeting leader can authorise a feature for the organisation's own purposes; they cannot give consent on behalf of a client, a candidate or a colleague in another country.

So build a process that does not rely on the vendor's prompt:

- **Before the meeting:** say so in the invitation. "This meeting will be transcribed and summarised by [tool]. Reply or tell us if you would prefer it was not."
- **At the start:** the host says it aloud and waits. "We're using an AI assistant to take notes. It creates a transcript and summary. Is anyone uncomfortable with that?"
- **During the meeting:** a visible indicator stays on screen and the bot is named clearly, not "Guest 1".
- **After the meeting:** the summary goes only to people who attended and agreed, and says how long it will be kept.

A notice you can defend: before, at the start, during and after

What good notice contains

A notice that works is short, specific and honest. It covers:

- **That** the meeting will be recorded, transcribed or summarised, and by which tool.
- **Why**: "to produce accurate notes and action items", not "to improve our services".
- **What happens to it**: who can see it, how long it is kept, whether the vendor may use it to train models.

- **How to say no**: a named person, and an actual alternative such as human notes or an off-the-record segment.
- **Where to read more**: a link to your privacy notice.

Avoid the vague phrase "this call may be recorded for quality purposes". It tells nobody what is being captured, who by or for how long, and it will not satisfy the GDPR's transparency duty (Chapter 3). Sample wording for invitations, openings and external clients is in Appendix D.

What if someone says no?

Plan for it before it happens, because a bot cannot be half-removed once it has heard the first sentence. Your options, in order of preference:

1. **Switch it off** and take notes manually. This is the default when someone objects, particularly a client, candidate or employee.
2. **Offer a limited alternative**: a recording of only the presentation, with discussion off the record.
3. **Move the sensitive part** of the conversation to a call without the assistant.
4. **Decline to proceed** with the assistant and say so politely. A meeting is rarely so important that a participant's objection should be overridden.

What you must not do is carry on and hope. A person who says no and is recorded anyway has been given a real grievance. In an employment setting, "everyone could leave if they didn't like it" is not a defence, because a person who is invited to the meeting by their manager does not feel free to leave it.

Back-channel recorders

A rule about visible bots does little if the real risk is a phone on the table. Your policy should state plainly that **nobody may record, transcribe or summarise a work meeting by any means, including personal devices, unless the participants have been told and the tool is approved**. This protects staff as much as it protects the organisation. It also gives you something concrete to point to when an uninvited recorder turns up, and it covers in-person and hybrid meetings, where the room itself is the microphone.

Worked example (fictional): the client who said no

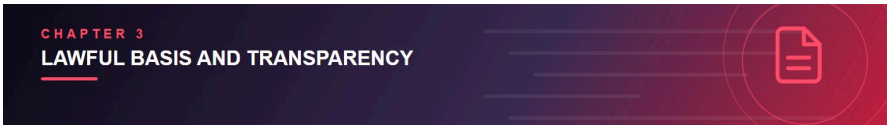
Asel, a consultant, opens a call with a prospective client with: "I use an AI assistant to take notes. It produces a transcript and summary that only I can see, kept for thirty days. Would you mind?" The client hesitates and says he would rather not, because they will discuss an unannounced acquisition. Asel switches the assistant off, confirms on screen that it has stopped, and takes handwritten notes. The client, visibly relieved, says afterwards that a competitor's adviser had recorded him without asking and he had not hired them.

Asel lost nothing and gained a reason to be trusted. The cost of asking is thirty seconds. The cost of not asking can be the client.

> **The rule:** The host's click is not the participants' consent. Tell everyone, name the tool, and make saying no cost nothing.

CHAPTER 3

Lawful Basis and Transparency Under the GDPR



A tidy desk with a notebook: the oldest form of meeting notes, and still the benchmark for what is necessary

If any participant is in the European Economic Area, or you are established there, the GDPR applies to the personal data an assistant produces. A voice is personal data. So is a name, a statement about someone's performance, an opinion, a health remark made in passing, and the fact that a given person attended a given meeting. Nearly every transcript contains personal data about people other than the speaker.

That means every use of a meeting assistant needs what the GDPR calls a **lawful basis**, a recorded reason from a short list, and it needs to be **transparent** about it.[6] This chapter takes the legal ideas in order and translates each into a decision you can make.

You, the vendor and the roles

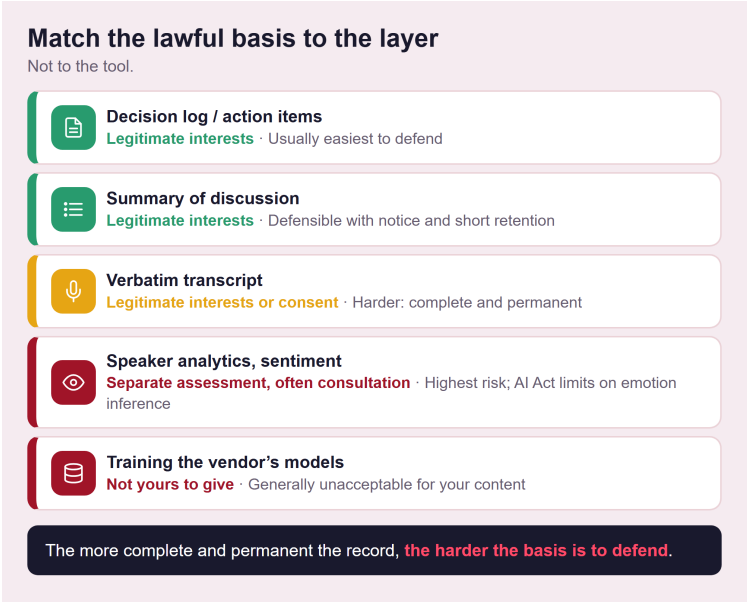
Start with who is responsible for what, because it shapes the contract (Chapter 5).

- You are normally the **controller**: you decide that the meeting will be transcribed and why.
- The vendor is normally your **processor**: it handles the data on your instructions, under a written agreement.

- If the vendor uses your recordings for its own purposes, such as improving its models, it starts to look like a **controller** or joint controller for that use. That changes your obligations significantly and is often why such terms are unacceptable. Chapter 5 returns to this.

Pick the basis for each layer, not for the tool

The mistake is to ask "what is our basis for using the notetaker?" The better question is: **what is our basis for each thing it produces?** Different layers justify different reasons.



Match the basis to the layer: summaries, verbatim transcripts, speaker analytics and training each need their own answer

Legitimate interests (Article 6(1)(f)) is the basis most organisations will reach for. It asks three questions in order: is there a genuine interest (accurate notes, accessibility, follow-through), is the processing *necessary* for it, and do the individual's rights and expectations outweigh it? You should write the answer down. This is called a **legitimate interests assessment**, and the third question is the one that matters: a participant who has been told in advance and has a way to object has a reasonable expectation; a person recorded secretly by a bot they never saw does not.

German regulators are reported to take a layered view, with some treating legitimate interests as a workable basis for summaries or purely live transcription without stored audio, but expecting consent for full verbatim transcripts. This position is from secondary summaries, not the authorities' own wording, so check your own regulator.[7] The practical lesson holds anywhere: **the more complete and permanent the record, the harder your basis becomes to defend.**

Consent (Article 6(1)(a)) looks tempting because it feels clean, but it has to be freely given, specific, informed and as easy to withdraw as to give. Two things undermine it at work. First, an employee who is invited to a meeting by their manager is rarely in a position to refuse freely, so regulators have long been sceptical of employee consent.[13] Second, withdrawal has to be real: if one participant withdraws mid-call, you need a way to stop capturing them. Consent works best for external guests and optional recordings, not as the foundation of a staff policy.

Contract (Article 6(1)(b)) will rarely apply. The test is whether the processing is *objectively necessary* to perform a contract with the person. Meeting minutes may be convenient; they are seldom necessary to perform an employment contract.

Legal obligation (Article 6(1)(c)) covers a few cases, such as a regulated sector that requires recording certain communications. In those cases the law, not a notetaker's marketing page, defines what you must record.

Special-category data adds a second layer. A passing mention of someone's health, trade-union membership or religion in a meeting is special-category data (Article 9), which needs a separate condition on top of the ordinary basis. You cannot predict what will be said, which is one of the strongest arguments for **not recording sensitive meetings at all** (Chapter 4).

The three-layer test

When you cannot decide, run the same three questions on each layer of output:

1. **Necessary?** Could a human note, a short written summary or a decision log do the job with less data?
2. **Expected?** Would a reasonable participant, told in advance, expect this to happen to what they say?
3. **Controllable?** Can you restrict access, limit retention, honour an objection and delete it?

If any answer is no, change the design before you rely on the basis: summarise rather than transcribe, shorten retention, or do not use the tool for that meeting.

Transparency: telling people what you do

Articles 13 and 14 require you to give people specified information about the processing: who you are, why, on what basis, who receives the data, whether it goes outside the EEA, how long you keep it and what rights they have.[6] For meeting assistants, that information needs to reach three groups through different routes:

- **Employees:** the staff privacy notice, updated to name meeting assistants, plus your policy.
- **External participants:** a short notice in the invitation and at the start, with a link to your public privacy notice.
- **Candidates:** the recruitment privacy notice, and a specific line in the interview invitation, before the interview begins.

A privacy notice that does not mention AI meeting tools, when you use them, is out of date. Updating it is an hour's work and one of the cheapest risk reductions available.

Minimisation and purpose

Two further principles do real work. **Data minimisation** means collecting only what you need. A tool that is set up to keep audio forever, transcribe every word and run sentiment analysis is, by design, collecting more than a decision log requires. **Purpose limitation** means that notes made to record action items must not quietly become evidence for a performance review, a marketing database or a training set. If you want to reuse the data for something new, you need a new look at the basis and, usually, new notice.

When you need a DPIA

A **data protection impact assessment** (Article 35) is required for processing likely to result in a high risk, and regulators publish lists of examples. Systematic recording and analysis of employees' conversations, particularly with scoring, large-scale use or vulnerable people, is the kind of project that commonly triggers one.[14] For a small team using a native assistant with human-reviewed summaries and

short retention, a short written assessment is usually enough. For an organisation-wide rollout with analytics, treat the DPIA as mandatory. The tables in the appendices give you most of the content.

People's rights

Transcripts are personal data about the people in them, so they can ask for them. A person can ask what you hold about them (access), ask for errors to be corrected, and in some circumstances ask for erasure or object. A transcript in which three colleagues are discussed is difficult to disclose without exposing the others, which is another reason to keep fewer of them for less time. Make sure you can **find** a person's data across the vendor's platform, and that your vendor's contract obliges them to help you respond. If you cannot search your own archive, you cannot answer a request.

Worked example (fictional): the interview that was transcribed

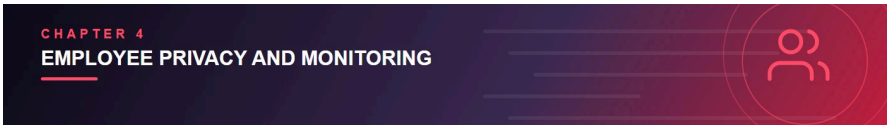
Rhea, an HR manager at a seventy-person firm, uses a bot to transcribe job interviews so that panellists can compare notes. A candidate later asks for "all the data you hold about me". The transcript contains her answers, the panel's candid comments about her and, at one point, a remark about her pregnancy plans made by a panellist who should not have asked.

Rhea now has a request to answer, a transcript containing special-category data and an unlawful question on record. The way to have avoided the worst of it was simple: tell the candidate in advance, keep a human-written scoring sheet as the official record, switch the bot off for interviews, and delete any transcript within days. The transcript had been made for convenience. It became the most dangerous document in the file.

> **The rule:** Choose the lawful basis for each layer of output, not for the tool. The more complete and permanent the record, the harder it is to defend.

CHAPTER 4

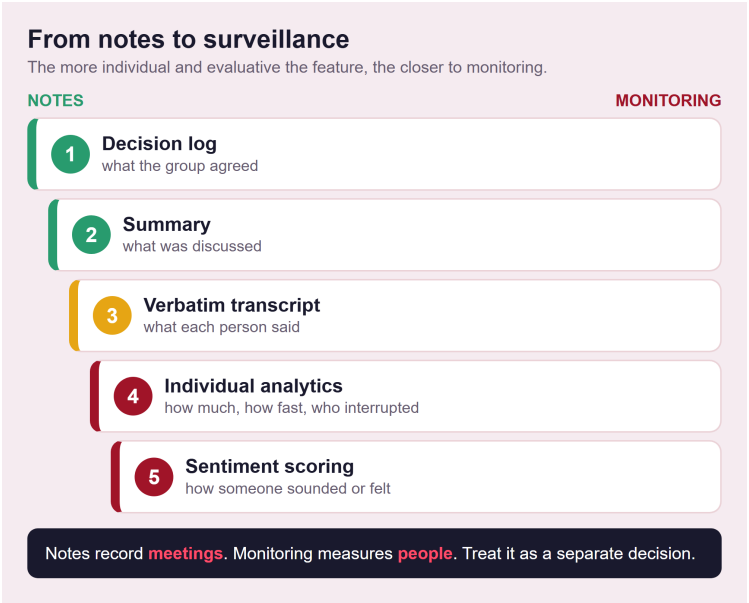
Employee Privacy and Workplace Monitoring



A headset left on a desk: the person using it is entitled to privacy even when the device belongs to the company

A meeting assistant used well produces **notes**. Used loosely, the same product turns into **monitoring**: a standing record of how individuals speak, behave and perform. The line between them is the central employment-law question of this book, and it is easy to cross by accident because the same feature set serves both.

Notes versus monitoring



From notes to surveillance: the more individual and the more evaluative a feature, the closer it sits to monitoring

Think of a spectrum.

- **A decision log** records what the group agreed. Low privacy impact.
- **Summaries and action items** record what was discussed and who owns what. Moderate.
- **Verbatim transcripts** record exactly what individuals said. Higher; they create a quotable record.
- **Individual analytics** measure how much each person spoke, how quickly, how many filler words, who interrupted whom. These measure people, not meetings.
- **Sentiment or "engagement" scoring** infers feelings, attention or attitude. This is the far end.

Holland & Knight's August 2026 analysis highlights this point: some assistants go beyond transcription to analyse speaking time, speech speed and sentiment, which raises employee-monitoring concerns in addition to the privacy ones, and several US states require notice for electronic monitoring of employees.[2][12] European law is generally stricter, not looser: employee monitoring has to be necessary,

proportionate and transparent, and in several countries it requires consultation with, or the agreement of, a works council or equivalent body before it begins.

The AI Act's red line

The EU AI Act prohibits AI systems that infer the emotions of people **in the workplace**, with narrow exceptions for medical or safety purposes. Article 5(1)(f) is part of the prohibitions that have applied since February 2025, and the Commission's guidelines on prohibited practices discuss it in detail.[8] Two cautions are important.

First, the prohibition is framed around systems that use **biometric data** to infer emotions, such as voice or facial characteristics; commentators differ about its exact edges, and plain transcription is generally outside it. Second, that is exactly why feature-level questions matter. A tool that transcribes is one thing. A tool that claims to detect that your colleague "sounded disengaged" from their voice may be heading towards the prohibited territory.

You do not need to resolve the legal edge cases to act sensibly. **Switch off emotion, sentiment and engagement scoring of staff, and ask your vendor in writing whether any feature infers emotion from voice or face.** Their answer, and the date, goes in your vendor file.

Proportionality and the power gap

Even without analytics, the employment relationship tilts every decision. An employee cannot easily refuse a manager's tool, and a recording of a performance conversation changes the conversation. Regulators and courts have long asked employers to consider three things: is there a **legitimate and specific purpose**, is monitoring **necessary** (could something less intrusive achieve the same result), and is the intrusion **proportionate** to the benefit.[13]

Applied to meetings:

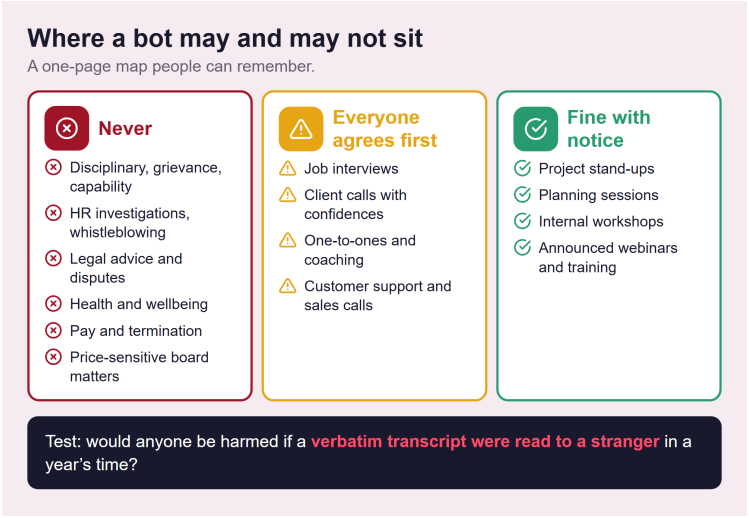
- **Purpose.** "To produce accurate minutes of project meetings" is a purpose. "To keep an eye on how people perform" is a different one, and has to be declared as such, assessed, and in many countries negotiated.
- **Necessity.** If a shared notes document would work, recording is hard to justify.

- **Proportionality.** Recording a weekly stand-up is not the same as recording every one-to-one.

Works councils and consultation

In some countries, introducing technology capable of monitoring employees triggers a legal duty to inform and consult, or to obtain agreement from, an employee representative body. Whether a meeting assistant counts as such technology can depend on its analytics features rather than on its transcription. Check your national rules and your existing agreements before a rollout, not after. Where a body exists, involving it early is nearly always cheaper than undoing a deployment.

No-bot zones



Meetings where an assistant should never run, and where it can: a simple sensitivity map

The simplest protection for the most sensitive conversations is a rule that bots are not allowed in them. A sensible starting list, expanded in Appendix B:

Never use an assistant for:

- Disciplinary, grievance, capability and redundancy meetings.
- HR investigations and whistleblowing conversations.
- Conversations with a lawyer, or about legal advice, claims or disputes, where privilege matters. Law firms warn that an AI transcript may fall outside privilege or waive it.[5]

- Health, occupational-health or wellbeing discussions.
- Pay, bonus and termination negotiations.
- Board discussions of acquisitions, financing or other price-sensitive matters, unless approved in advance.
- Meetings with minors or vulnerable people, and anything involving special-category data.

Use only with the explicit agreement of all participants:

- Interviews and candidate calls.
- Client or customer calls containing their confidential information.
- One-to-ones and coaching sessions.

Generally fine, with notice:

- Project stand-ups, planning sessions and internal workshops.
- Webinars and training, with clear announcement.

A list on one page that people can remember beats a policy they cannot recall.

Employees' own meetings

Staff also have private reasons to keep conversations off the record: a union conversation, a conversation about a health condition, a call with a recruiter. Make it clear that using a work notetaker does not entitle the employer to review recordings for unrelated purposes, and that managers must not use a transcript of a team meeting to build a case against an individual without following the proper process. If transcripts do become evidence in a dispute, an employee will ask why they were kept at all.

Worked example (fictional): the dashboard nobody asked for

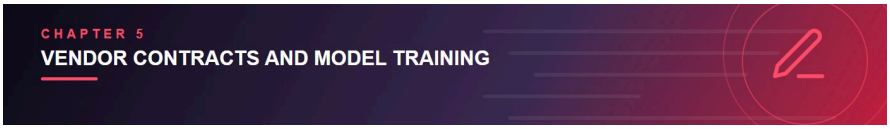
Kestrel Logistics, a two-hundred-person freight company, activates the "insights" module of its notetaker. Within a week, a manager shares a chart ranking depot supervisors by "talk-time" and "positivity". A supervisor sees it and asks the works council whether anyone agreed to this. Nobody had. The council demands the feature be switched off and the data deleted, and the company spends a month renegotiating its meeting policy.

The transcription had been uncontroversial. The scoring was not. The fix was to disable analytics, delete the scores, brief the managers on what the tool may be used for, and put the question of analytics through the proper consultation before ever turning it on again.

The rule: Notes record meetings; monitoring measures people. Keep the first, and treat the second as a separate decision that needs its own justification, notice and, often, consultation.

CHAPTER 5

Vendor Contracts and AI Model Training



Terms that no one reads are still terms: the contract decides what the vendor may do with your meetings

When you press "accept" on a notetaker's sign-up page, you are signing a contract about the most intimate record your business produces. This chapter explains which terms matter, what to ask for and what to walk away from.

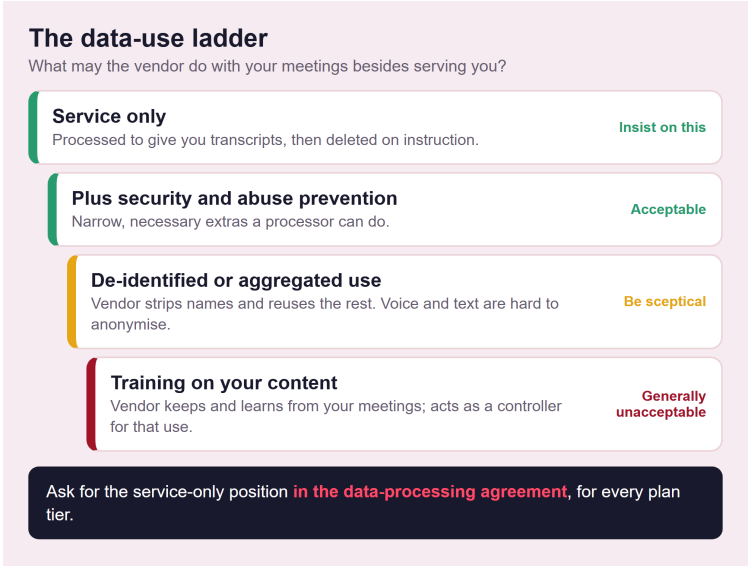
Terms of service are not a data-processing agreement

Free and self-service notetakers are usually offered under **consumer-style terms of service**. They describe what the vendor may do with the content you give it, and they are written for the vendor's benefit. A GDPR-compliant arrangement requires something more: a written **data processing agreement** (Article 28) that binds the vendor to handle personal data only on your instructions, keep it secure, use only approved sub-processors, assist with people's rights, delete or return the data at the end and allow audits.[6]

If the only paper you have is a sign-up page, you almost certainly do not have that. In practice the choice is plain: **move to a business plan with a signed agreement, or stop using the tool for anything involving personal data.** A free account that sits on a personal email address is worse still: you cannot administer it, you cannot see it, and you cannot demand its deletion when the person leaves.

The training question

The single most consequential clause is the one that says what the vendor may do with your content **besides serving you**. The pattern to look for is whether recordings, transcripts or derived data may be used to **train or improve the vendor's models**.



The data-use ladder: from serving you, through de-identified use, to training on your content

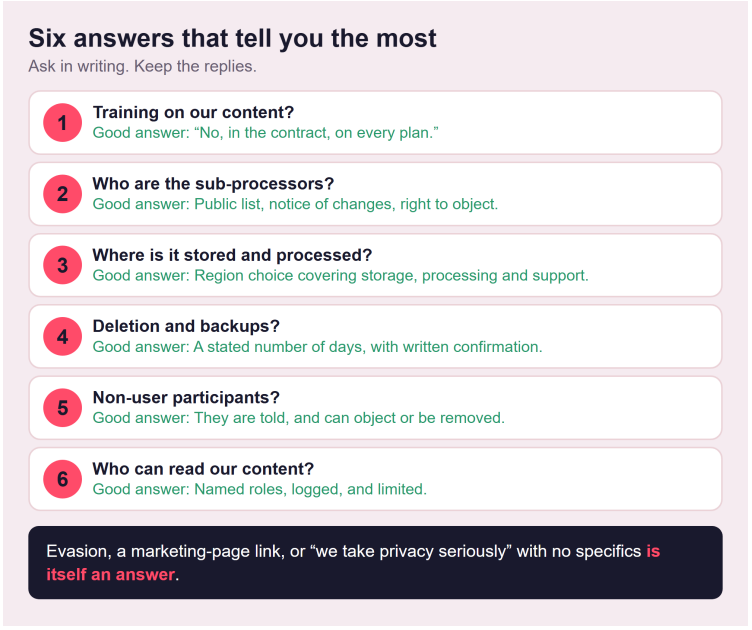
Think of a ladder:

1. **Service only.** The vendor processes your meetings solely to give you your transcripts and summaries, then deletes them as instructed. This is the position to insist on.
2. **Service plus security and abuse prevention.** Narrow, necessary extras that a processor can legitimately do.
3. **De-identified or aggregated use.** The vendor says it strips names and uses the rest to improve its products. Be sceptical. Voice recordings and verbatim text are very hard to anonymise: the content itself identifies people, and a vendor that will not explain its method publicly has given you little to rely on. The Otter complaint itself questions exactly this point, claiming that the company's de-identification process is not publicly explained.[3]
4. **Training on your content.** The vendor keeps and learns from your recordings. For confidential business conversations and anyone else's personal data, this is generally unacceptable, and for the vendor it makes it look like a controller for that use.

Ask for the **service-only position in writing**, in the data-processing agreement rather than a marketing page, and confirm whether it applies to every plan tier. Some vendors offer training opt-outs only on paid or enterprise plans, or require you to find a setting. Others use a separate "human review" programme. Ask about both.

The questions that matter

You do not need a procurement department. Fourteen questions, in the questionnaire at Appendix C, cover nearly everything. The ones that decide most outcomes:



Six answers that tell you the most about a vendor, and what a good one looks like

1. **Do you use customer content to train models, now or in future, and where is that in the contract?**
2. **Who are your sub-processors, and will you tell us before adding one?**
3. **Where are recordings and transcripts stored and processed, and can we choose the region?**
4. **How long do you keep data after we delete it, including backups and logs?**
5. **How do you handle a participant who never signed up: what do they see, and can they object?**

6. **Who at your company can read our content, and under what circumstances?**

A good vendor answers these quickly, in writing. An evasive answer, a pointer to a marketing page, or "we take privacy very seriously" with no specifics tells you what you need to know.

Other terms to check

- **Ownership of outputs.** You should own the transcripts and summaries. Watch for licences that let the vendor reuse them.
- **Confidentiality.** Staff access should be limited and logged. If the vendor's employees can read your meetings for "quality", that is a disclosure.
- **Security.** Look for recognised certifications or audit reports, encryption in transit and at rest, access controls and single sign-on. Treat certification claims as questions to verify, not facts to assume.
- **Breach notification.** The agreement should oblige the vendor to tell you promptly, so that you can meet your own 72-hour duty to notify the regulator where it applies.
- **Deletion at exit.** On termination, what do you get back and in what format, and when is everything else deleted and confirmed?
- **Liability.** Many vendors cap liability at a few months' fees. For a tool that holds your sensitive conversations, understand what that cap means for you.
- **Changes.** Terms change. Ask how you will be notified, and note the date you last reviewed them.
- **Subcontracted AI models.** The summary may be written by a third-party model provider. That provider is a sub-processor and must be covered (Chapter 6).

Native tools are not exempt

If you use a built-in assistant from your conferencing or collaboration platform, the same questions apply, though you often start from a stronger contract. Check that its AI features are covered by your existing data-processing terms, what the default retention is, who can switch features on, and whether any customer content is used for training. Vendors' defaults change; the documents that describe them change too, so verify against current admin documentation, not memory or a university help page.[10]

Worked example (fictional): the free plan that kept everything

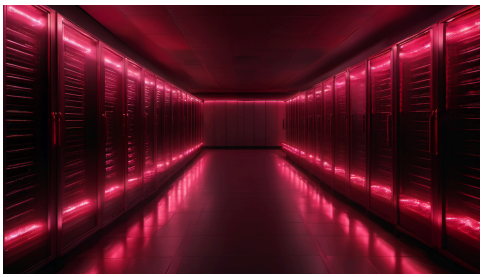
A four-person accountancy practice uses a free notetaker for client meetings. After a client asks where their call recording is held, the practice reads the terms for the first time. They grant the vendor a licence to use content "to develop and improve our services". There is no data-processing agreement and no way to select a storage region. Deletion requires a request to support, and backups are not mentioned.

The practice moves to a paid business plan from the same vendor, signs the agreement, confirms in writing that content is not used for training, switches storage to an EU region, deletes the old account's recordings and tells the affected clients what happened. It costs a few hundred euros a year. The alternative was explaining to clients why their financial discussions had been used to improve a product they had never heard of.

> **The rule:** If you cannot show a signed agreement that says your meetings are used only to serve you, assume they are being used for more.

CHAPTER 6

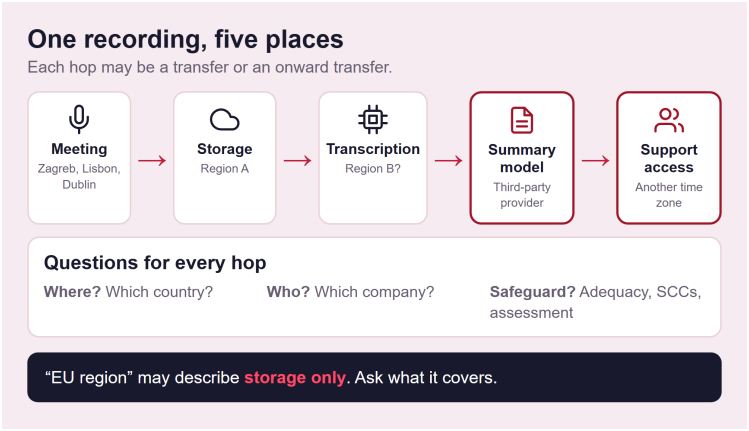
International Transfers and Subprocessors



A server corridor at night: data lives somewhere physical, and the law cares which country that is

A meeting that happens in Zagreb, Lisbon or Dublin can be processed in a data centre in Virginia, summarised by a model hosted in a third country and supported by an engineer in another time zone. Each of those hops may be a **transfer** or an **onward transfer** under the GDPR, and each may involve a company you have never heard of.

Follow the data



A single recording's journey: storage, transcription, summarisation, support and backup can each sit in a different place with a different company

For each assistant you use, draw the route a recording takes. At minimum, find out:

- **Where it is stored**: the region of the primary data store, and where backups and logs sit.
- **Where it is processed**: where transcription and summarisation run. This may differ from storage.
- **Who is involved**: the vendor, its cloud host, its speech and language-model providers, and any analytics or support tools that see content.
- **Who can reach it remotely**: support and engineering staff in other countries who can open a customer's data count as access from there.

Vendors publish a list of sub-processors; read it. If the list is missing, out of date or includes a company that produces AI models, you have found a gap.

The transfer rules in plain English

Under Chapter V of the GDPR, personal data may leave the EEA only if there is a valid route.[6] The routes you will actually meet:

- **An adequacy decision.** The Commission has decided that a country's protections are essentially equivalent. For the United States this is the **EU-US Data Privacy Framework**, which covers only US companies

that have certified to it, so you must check the vendor's certification and that it covers the relevant data.

- **Standard contractual clauses (SCCs).** Approved contract terms that the vendor and you (or the vendor and its sub-processors) sign, usually combined with a **transfer impact assessment** looking at the destination country's laws and the safeguards in place. This is the route when there is no adequacy decision, or as a backstop.
- **Other tools**, such as binding corporate rules or narrow derogations. These are rarely suitable for routine meeting data.

The Data Privacy Framework: stable, but not settled

The Framework survived a first challenge when the EU General Court dismissed an annulment action in September 2025. The applicant appealed to the Court of Justice, and the appeal is, according to reports as of mid-2026, still pending.[9] Advisers' consistent message is practical: **keep using a valid transfer tool, but do not make it your only one.** If you rely on the Framework, also keep a fallback, such as SCCs in the vendor's agreement, and know how quickly you could move data or change vendor if the legal footing shifted. Previous invalidations of transfer mechanisms came with little warning, which is why teams that planned an exit calmly fared better than those who scrambled.

Choose region, and then check it

Many business plans let you choose an EU data region. This is worth doing, but read what it actually covers. Some "EU region" options apply only to storage, while processing, support access or the AI model may still run elsewhere. Ask directly: **"Does the EU region cover storage, transcription, summarisation and support access, and which sub-processors are outside it?"**

A related point: sending content to a US-owned vendor's EU data centre does not by itself remove every transfer or access issue, and equally does not make it unlawful. The point of the exercise is to know, to document the route and the safeguard and to be able to explain it, rather than to chase an impossible absolute.

Subprocessors you must be able to accept

The vendor must have your authorisation, general or specific, before engaging a sub-processor, and must flow down equivalent obligations to it. In practice, good contracts give you:

- A **public list** of sub-processors, with locations and what each does.
- **Advance notice** of changes, typically thirty days, and a right to object.
- A **remedy** if you object, such as the right to terminate without penalty.

Subscribe to the notice if there is a mailing list. Put the review date in your calendar. Without notice, you cannot exercise a right you have on paper.

Language models are subprocessors too

Many assistants send transcripts to a third-party large language model to write summaries. That provider is a sub-processor. Ask whether it is bound by a no-training, no-retention commitment, whether the transcript is stored on its side, and which country it runs in. If the summary is generated "in the cloud" and the vendor cannot say where, treat that as an unanswered question rather than a reassurance.

Worked example (fictional): the support engineer in another time zone

A Lisbon-based architecture firm picks an assistant with an EU storage region and considers the matter closed. Months later, an employee raises a support ticket, and a vendor engineer in a non-EU country opens the account to investigate. The firm's contract was silent on support access, and the sub-processor list included the vendor's own support tool, whose location the vendor does not state.

The firm requests clarification. The vendor responds that support access is possible from outside the EEA under its standard clauses, and offers a restricted-access option for an extra fee. The firm documents the risk, accepts the offer and records the decision. The lesson is not that the vendor was dishonest. It is that "EU region" described only one part of the route.

> **The rule:** Know the route. Every country the recording passes through and every company that touches it should be on a list you can read, and each should have a safeguard you can name.

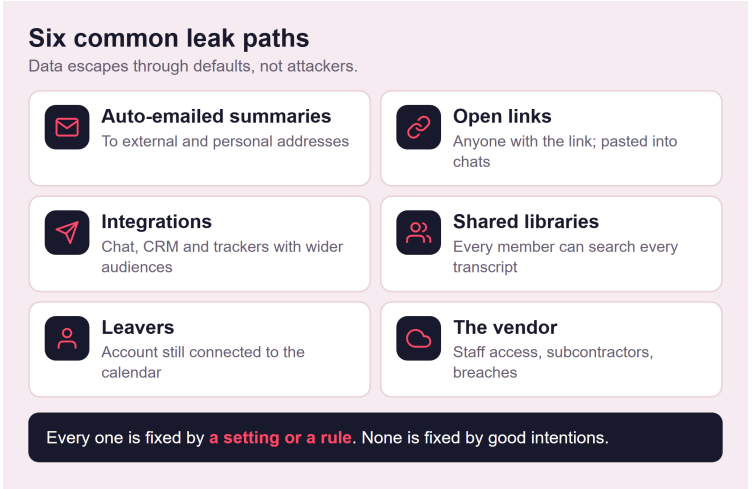
CHAPTER 7

Access Restrictions and Deletion Procedures

An archive with no label on the shelves: a record you cannot find is a record you cannot delete

Everything so far has been about whether to capture a conversation. This chapter is about what happens afterwards, which is where most real harm occurs. A transcript that no one can read is harmless. A transcript that everyone can read, forwards, indexes and keeps forever is a liability that grows every day.

How transcripts leak



Six common leak paths: summaries, links, integrations, shared folders, ex-employees and the vendor itself

Meeting data rarely escapes through an attack. It leaks through **defaults and convenience**:

- **Auto-emailed summaries.** The tool sends the recap to everyone on the invitation, including external guests, personal addresses and distribution lists.
- **Shareable links.** A link to a transcript that works for anyone who has it, which gets pasted into a chat, forwarded or indexed.
- **Integrations.** Summaries pushed to chat channels, CRMs and task trackers that have broader audiences than the meeting did.
- **Shared workspaces.** Folders or libraries where every member can search every transcript.
- **Departed people.** An ex-employee's account, still connected to the calendar, still holding years of recordings.
- **The vendor.** Staff access, subcontractors, and the vendor's own breaches.

Each is fixed by a setting or a rule. None of them is fixed by good intentions.

Default to the narrowest audience

The principle is **least privilege**: a recording should be visible to the smallest group that needs it, for the shortest time that it needs it.

- **Private by default.** Only the organiser, or only those who attended and were informed, can open a transcript.
- **No auto-sharing outside the organisation.** Summaries to external participants should be a deliberate, reviewed act, not an automatic one.
- **Links expire and require sign-in.** Anyone-with-the-link access should be off.
- **Role-based access for sensitive teams.** HR, finance and legal meetings should be separate from the general library, with their own owners.
- **Admin controls on.** Single sign-on, multi-factor authentication and audit logs, so you can see who opened what.
- **Download and export restricted.** Every export is a copy outside your control.

Walk through your tool's admin settings with a checklist (Appendix A has one) and record the date and who did it. A setting you cannot show was configured is a setting you cannot rely on.

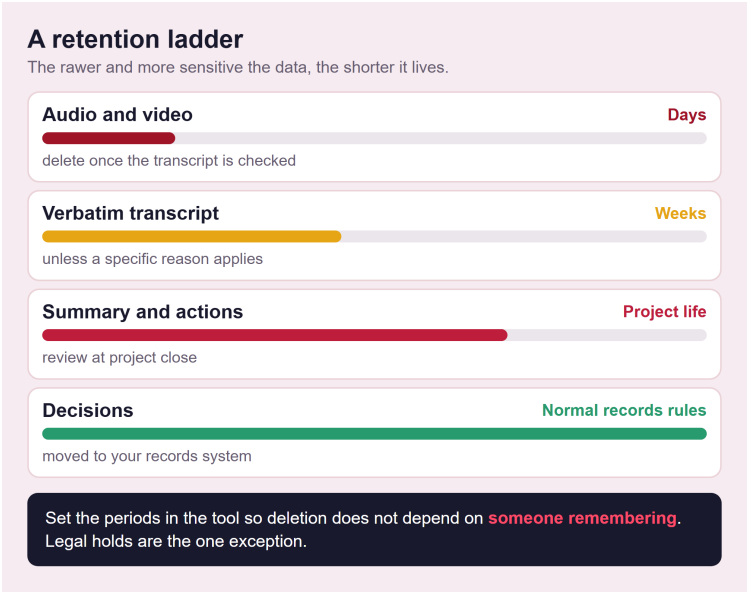
Summaries need a human

A summary is the most-shared artefact and the least checked. Language models can misattribute a statement, invent an action item or flatten nuance into a false certainty. In a legal or HR setting, an inaccurate summary that is filed as the record is worse than no record. Rules that help:

- **The organiser reviews before it goes anywhere else.** A thirty-second skim catches most errors.
- **Mark it as machine-generated.** "Draft: produced by an AI assistant and not checked word for word."
- **Treat it as a working aid, not an official minute.** Where a formal record is required, a person writes it.
- **Let people correct it.** A participant who spots an error about themselves should have a simple way to ask for it to be fixed.

Retention: decide a number

Without a rule, recordings last as long as the account. The remedy is a **retention schedule** written for each type of output, with a trigger and a number.



A retention ladder: audio goes first, then transcripts, then summaries, and only decisions are kept

There are no universal numbers. A reasonable starting design is a ladder in which the more raw and the more sensitive the data, the shorter it lives:

- **Audio and video:** delete as soon as the transcript is checked, or within days.
- **Verbatim transcripts:** delete within weeks, unless a specific reason applies.
- **Summaries and action items:** keep for as long as the project needs them, and review at project close.
- **Decisions and outcomes:** move the lasting content, the decision itself, into your normal records system, where your usual retention rules apply, and let the rest go.

Write the period down, justify it and set the tool to enforce it automatically wherever it can. Retention that depends on someone remembering to delete is retention that will not happen. Remember the storage-limitation principle: personal data may not be kept longer than necessary for the purpose.

Legal holds are the exception. If a dispute, investigation or regulatory request is reasonably foreseeable, you may need to preserve relevant records. Make sure someone has authority to pause deletion for specific

meetings, and that the pause is recorded and ended when it should be. Otherwise your retention policy will either destroy evidence or quietly fail.

Deletion that is real

Clicking "delete" is a request, not a proof. A complete deletion procedure answers:

1. **Where are all the copies?** In the vendor's primary store, in backups, in email, in chat channels, in task trackers, in downloaded files, in other tools the summary was pushed to.
2. **Who owns each deletion?** One named person per system.
3. **How long does it take?** Vendors often keep backups and logs for a further period. Get the number in writing.
4. **How do you confirm it?** Ask for written confirmation, and spot-check by searching for something you know was deleted.
5. **What about training and derived data?** If the vendor has already used the content, deletion from your account may not undo that. This is another reason to prohibit training at the start (Chapter 5).

Keep a simple **deletion log**: what, when, who, how confirmed. It is the evidence you will want in a complaint, an audit or a client's question, and Appendix F gives you a template.

Leavers, transfers and shared accounts

Offboarding must include the notetaker. When someone leaves:

- Disconnect their calendar and revoke the assistant's access.
- Decide what happens to their recordings: delete, transfer to a manager or archive under the retention rule.
- Remove any personal accounts that were used for work, and ask the former employee to confirm deletion where appropriate.

Never let a bot continue to attend meetings under a departed person's identity. Shared team accounts should be avoided because they hide who did what.

If something goes wrong

A transcript sent to the wrong person, a link exposed publicly or a vendor breach is a personal data incident. Your incident procedure should cover it, including the question of whether the 72-hour regulator notification and notification of affected individuals apply, which depends on the risk to people.[6] Practical steps: revoke the link or access, record what was exposed and to whom, ask the recipient to delete and confirm, contact the vendor, and assess. For a small business the most important preparation is to know **who decides** and to have their number.

Worked example (fictional): the link in the group chat

At Brightwell Care, a charity with thirty staff, a coordinator shares a transcript link in a team chat so colleagues can find a decision. The transcript includes a discussion of a named service user's circumstances. The link requires no sign-in and the chat has an external volunteer in it. Two weeks later a volunteer mentions the circumstance to someone outside the organisation.

Brightwell revokes the link, identifies the exposure, assesses it as a personal data incident, informs its data-protection lead and the affected person, and records its decision. Afterwards it switches off public links, restricts the workspace and sets a thirty-day transcript lifetime. The incident was not caused by bad people. It was caused by a default, and fixed by changing the default.

> **The rule:** The audience, the lifetime and the deletion procedure are not afterthoughts. They are the controls that decide whether a recording stays an asset or becomes an incident.

CHAPTER 8

A Responsible AI Meeting Policy

CHAPTER 8
A RESPONSIBLE AI MEETING POLICY

A calm office in morning light: a policy is meant to make the ordinary working day quieter, not busier

A policy is the document that turns this book's decisions into behaviour. Its job is not to impress an auditor. It is to let a new starter in a hurry, with a bot invitation in their inbox, do the right thing without calling anyone.

What a good policy looks like

- **One page.** If it needs scrolling, nobody will read it. Longer detail belongs in a supporting procedure.
- **Plain words and concrete rules.** "Tell everyone at the start" rather than "ensure transparent processing".
- **Specific about tools.** Name the approved assistants and say that others are not allowed.
- **Honest about the reasons.** People follow rules they understand.
- **Owned.** A named person responsible for updates, exceptions and questions.

A one-page template is in Appendix E. The core elements are these.

Purpose and scope. Why the organisation uses meeting assistants, and which meetings, people and devices the policy covers. Include in-person and hybrid meetings, and contractors.

Approved tools only. A short list of assistants and the account type allowed. Anything else, including free personal tools and plug-ins, is not permitted for work meetings. Automatic joining is switched off unless approved.

Tell everyone, every time. The invitation line, the opening statement and the visible indicator (Chapter 2). A named alternative for anyone who objects.

No-bot zones. The meeting types where assistants are never used, and those that need explicit agreement (Chapter 4).

What the tools may be used for. Notes, accessibility and follow-up. Not performance scoring, emotion or sentiment analysis of staff, or building a case against an individual without proper process.

Who can see what. Private by default, no public links, summaries reviewed before sharing and no automatic distribution outside the organisation (Chapter 7).

How long it is kept. The retention numbers, who enforces them and how legal holds work.

Vendors and data. Only vendors with a signed agreement, no training on our content, known sub-processors and a recorded transfer route (Chapters 5 and 6).

Raising concerns. A named contact, no penalty for objecting and a route to report an unapproved recorder or an accidental disclosure.

Review. The policy is reviewed every six months, and whenever a tool or law changes materially.

Rolling it out in thirty days

A policy on a shared drive does nothing. A thirty-day plan does.

Thirty days from discovery to a policy people actually follow

Days 1 to 7: Find. Name an owner. Ask everyone what they use. Check admin consoles for connected apps and AI features. Fill in the assistant inventory (Appendix A). Switch off automatic joining everywhere you can.

Days 8 to 14: Decide. Classify your meetings with the sensitivity matrix (Appendix B). Choose the approved tools. Send the vendor questionnaire (Appendix C) and request signed agreements. Decide your retention numbers. Take advice on any area where the law is unclear to you: works councils, special-category data, regulated sectors.

Days 15 to 21: Write and configure. Adapt the policy (Appendix E) and the notice wording (Appendix D). Update your privacy notices. Set retention, sharing and access controls in each tool and record what you set. Draft a short DPIA from your inventory.

Days 22 to 30: Tell and test. Brief staff in twenty minutes, with the three rules that matter most: tell everyone, no-bot zones, delete on schedule. Run one real meeting using the notice process and ask a participant for honest feedback. Delete the legacy recordings you do not need, log it (Appendix F), and set the review dates.

You will not finish perfectly. You will finish with an inventory, an approved list, a policy and a habit, which is far better than most organisations manage.

Training that works

Short, specific and rehearsed beats long and generic. Cover:

- **What to say.** Practise the opening sentence aloud. It feels awkward once.
- **What to do when someone objects.** Switch off, confirm it has stopped and carry on.
- **What never to record.** The no-bot list, by heart.
- **What to do when something goes wrong.** Who to tell, and that it is safer to report an error immediately than to hide it.

Tell people the point of the training is to protect them as well. A manager who records a sensitive conversation without notice has put themselves in the firing line.

Measuring whether it works

Pick three numbers and look at them quarterly:

1. **Unapproved tools found.** Is the number falling?
2. **Meetings with a documented notice.** Spot-check ten recent recordings.
3. **Recordings past their retention date.** The answer should be zero.

Add one qualitative check: ask a few clients or staff whether they felt properly informed. They will tell you.

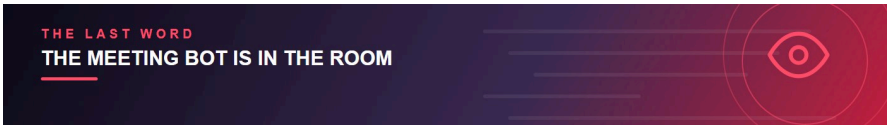
Worked example (fictional): the policy that fit on one page

Northlight Advisory, the consultancy from the introduction, rebuilt its approach after the incident. It approved a single paid assistant with a signed agreement and EU storage, switched off automatic joining, listed five no-bot meeting types, wrote a one-page policy and set a thirty-day transcript lifetime. The policy opens with the three sentences everyone says at the start of a call.

Six months later a prospective client asked, politely, whether the firm used AI to record meetings. Ines sent the policy and the notice wording by return, the client replied "that is the clearest answer I have had from anyone", and Northlight won the work. The policy had begun as a clean-up. It became a selling point.

The rule: A policy is only as good as the behaviour it changes. Keep it to a page, name the tools, say it aloud at the start of the meeting and review it twice a year.

Conclusion: Let the Room Know



A quiet street at blue hour: the aim is not to avoid the tools but to move through them with the lights on

Ines still uses an AI notetaker. So does almost everyone she works with. What changed is not the technology but the manner: every meeting starts with a sentence, every tool has an owner, every recording has an end date, and the most sensitive conversations take place with no assistant in the room.

That is the whole shape of responsible use. **Know what is in the room. Tell the people in it. Choose a reason you can write down. Keep the tools out of the conversations that matter most. Hold the vendor to a contract. Follow the data across borders. Limit who can see it. Delete it on time. Put it all on one page.**

None of this requires a large budget, and none of it is permanent. Laws will change, cases will be decided, vendors will rewrite their terms, and the tools will become more capable and harder to see. Your inventory, your policy and your habits are what let you adapt without panic.

The meeting bot is already in the room. The question is whether you invited it, whether everyone else knows it is there, and whether you can say what it does with what it hears. Start with the ten-minute check, fill in Appendix A this week, and let the room know.

APPENDIX A

AI Meeting-Assistant Inventory

Complete one row for every assistant found, including free tools, browser add-ons and the AI features built into your conferencing platforms. Ask staff without blame. Review every quarter.

Tool	Type (native, bot, device, plug-in)	Who uses it	Account (business or personal)	Auto-join on?	Signed agreement?	Trains on our data?	Storage region	Approved?

Admin settings check (record date and who checked):

- ☐ Automatic joining of meetings is off, or limited to named approved users.
- ☐ Recording and AI summary features can be started only by approved roles.
- ☐ Participants see a banner or prompt when recording or AI starts.
- ☐ Summaries are not emailed automatically to external or personal addresses.
- ☐ Public or anyone-with-the-link sharing is disabled.
- ☐ Single sign-on and multi-factor authentication are enforced.
- ☐ Retention and auto-delete are configured to the numbers in Appendix F.
- ☐ Sentiment, emotion and individual-analytics features are switched off.

- ☐ Third-party apps and add-ons need admin approval before they connect to calendars.

Checked by: _____ Date: _____

APPENDIX B

Meeting-Sensitivity Matrix

Sort each recurring meeting type into one of three columns. Adapt to your organisation, and have your lawyer, HR lead or works council check the red column.

Meeting type	Red: no assistant	Amber: only with every participant's agreement	Green: with notice
Disciplinary, grievance, capability, redundancy	✓		
HR investigation or whistleblowing	✓		
Legal advice, claims, disputes	✓		
Health or wellbeing discussion	✓		
Pay, bonus, termination	✓		
Board: financing, acquisition, price-sensitive	✓		
Job interview		✓	
Client call with confidential information		✓	
One-to-one or coaching		✓	
Customer support or sales call		✓	
Project stand-up or planning			✓
Internal workshop or training			✓
Webinar (announced)			✓
Your own types:			

The test for a new meeting type. Would anyone present be harmed, embarrassed or put at a disadvantage if a verbatim transcript were read aloud to a stranger in a year's time? If yes, it is red or amber.

APPENDIX C

Vendor Due-Diligence Questionnaire

Send to every vendor, including those you already use. Keep the answers, with the date and the name of the person who gave them.

#	Question	Answer	Acceptable?
1	Do you use customer content (audio, transcripts, summaries, derived data) to train or improve any model, yours or a third party's? Which plans? Where is this in the contract?		
2	Is there any human review of customer content, and under what circumstances?		
3	Will you sign a data-processing agreement that meets GDPR Article 28? Please attach it.		
4	List all sub-processors, their locations and functions. How will you notify us of changes, and may we object?		
5	Where are recordings and transcripts stored, processed and backed up? Does an EU region cover storage, processing and support access?		
6	What transfer mechanism applies to each non-EEA transfer (Data Privacy Framework certification, SCCs)? Is a transfer impact assessment available?		
7	Which third-party AI model providers handle our content, and are they bound by no-training and no-retention terms?		
8	What security certifications or audit reports can you provide? What encryption, access controls and logging apply?		
9	Who at your company can access our content, and how is access logged and limited?		
10	How and when will you tell us of a personal data breach?		

#	Question	Answer	Acceptable?
11	How long is data kept after deletion, including backups and logs? Do you give written confirmation?		
12	What do non-account participants see, and how can they object or have their data removed?		
13	Do any features infer emotion, sentiment or attention from voice, face or behaviour? Can they be switched off for all users?		
14	On termination, how do we export our data, and when is the rest deleted?		

Decision: ☐ Approve ☐ Approve with conditions ☐ Reject

Conditions:

Reviewed by: _____ Date: _____ Next review: _____

APPENDIX D

Participant Notice Wording

Adapt these, put them in your own voice and have them checked against your privacy notice.

1. Meeting invitation (internal)

> This meeting will be transcribed and summarised by [tool]. The summary will be shared only with attendees and deleted after [period]. If you would prefer not to be recorded, please tell [name] before the meeting and we will take notes by hand.

2. Meeting invitation (external guest or client)

> To keep accurate notes, we use an AI assistant ([tool]) that creates a transcript and summary of this call. It is visible in the participant list. The transcript is kept for [period], seen only by [who], and is not used to train AI models. You are welcome to say no, in which case we will switch it off. Our privacy notice is at [link].

3. Opening statement (say it aloud)

> Before we start: I'm using [tool] to take notes. It creates a transcript and a short summary that only I and [who] can see, and it's deleted after [period]. Does anyone mind? If so, I'll switch it off now.

4. If someone objects

> Of course. I've stopped it, and you can see the indicator is off. I'll take notes by hand. Thank you for telling me.

5. Candidate interview

> We do not record or transcribe interviews with an AI assistant. The panel takes written notes, which are kept under our recruitment privacy notice at [link].

6. Summary footer

> Draft: generated by an AI assistant and checked by [name] on [date]. It is not a verbatim record. To correct an error or ask about your data, contact [name/email].

7. When a bot joins uninvited (host message)

> An unrecognised assistant has joined this meeting. I'm removing it now. Please do not use a recorder or notetaker in this meeting without the host's agreement. If you added it, please let me know after the call so that we can make sure its recording is deleted.

APPENDIX E

Responsible AI Meeting Policy (One-Page Template)

[Organisation name]: Responsible AI Meeting Policy. Version _____ Date _____ Owner _____ Next review _____

1. Purpose and scope. We use AI meeting assistants to produce accurate notes and action items and to make meetings more accessible. This policy covers anyone attending or organising our meetings, in person, hybrid or online, including contractors, on any device.

2. Approved tools only. The approved assistants are: _____. No other recording, transcription or AI summary tool, including free apps, browser add-ons and personal accounts, may be used for our meetings. Automatic joining of meetings by any tool is not permitted unless the IT owner has approved it.

3. Tell everyone. The organiser must (a) say in the invitation that the assistant will be used, (b) say it aloud at the start and wait, and (c) ensure the tool is visible to participants. If anyone objects, switch it off and take notes by hand.

4. No-bot zones. Assistants are never used in: disciplinary, grievance and capability meetings; HR investigations and whistleblowing; legal advice or disputes; health or wellbeing discussions; pay and termination discussions; price-sensitive board matters. They are used in interviews, client calls and one-to-ones only with every participant's agreement.

5. What the tools are for. Notes, accessibility and follow-up. They must not be used to score performance, to infer emotion or sentiment, or to build a case against an individual without following the proper HR process. Individual analytics and emotion features are switched off.

6. Who sees what. Recordings and transcripts are private to the organiser unless shared deliberately. No public links. Summaries are reviewed by the organiser before being shared and are not sent automatically to external or personal addresses.

7. Retention. Audio: _____. Transcripts: _____. Summaries: _____. Decisions are copied to the normal records system. Legal holds are authorised only by _____.

8. Vendors. Only vendors with a signed data-processing agreement, no training on our content, a published sub-processor list and a documented transfer route.

9. Concerns. Raise any concern, objection, uninvited recorder or accidental disclosure with _____ immediately. Nobody will be penalised for objecting or for reporting an error.

10. Review. This policy is reviewed every six months and whenever a tool or the law changes materially.

APPENDIX F

Retention, Deletion Log and 30-Day Tracker

Retention schedule

Output	Where it lives	Retention period	Trigger	Auto-delete on?	Owner
Audio / video					
Verbatim transcript					
Summary and action items					
Chat and shared files					
Copies in email, chat, CRM, tracker					
Vendor backups and logs					

Deletion log

Date	What was deleted	System	Done by	Confirmation (how)

30-day rollout tracker

Task	Owner	Due	Done
Name policy owner		Day 1	☐
Switch off auto-join in all admin consoles		Day 3	☐
Staff survey: what is in use?		Day 5	☐

Task	Owner	Due	Done
Complete the inventory (Appendix A)		Day 7	☐
Classify meetings (Appendix B)		Day 10	☐
Send vendor questionnaires (Appendix C)		Day 12	☐
Decide retention numbers		Day 14	☐
Adapt policy and notices (Appendices D, E)		Day 18	☐
Update staff, candidate and public privacy notices		Day 20	☐
Configure sharing, retention and access		Day 21	☐
Short DPIA completed and signed off		Day 24	☐
Brief staff (20 minutes)		Day 26	☐
Run a pilot meeting and collect feedback		Day 28	☐
Delete legacy recordings; log it		Day 29	☐
Set 6-month review date		Day 30	☐

Glossary

AI meeting assistant. Software that records, transcribes, summarises or analyses a conversation.

Bot joiner. An assistant that enters a video call as an extra participant.

Controller. The organisation that decides why and how personal data is processed.

Data processing agreement (DPA). The written contract, required by GDPR Article 28, under which a processor handles data for a controller.

DPIA. A data protection impact assessment, required for processing likely to be high risk.

Data Privacy Framework. The EU-US adequacy arrangement covering certified US companies.

Legitimate interests. A GDPR lawful basis that balances your genuine interest against the individual's rights and expectations.

Lawful basis. The recorded legal reason, from the GDPR's short list, for processing personal data.

Model training. Using content to improve an AI system. A vendor doing so for its own purposes is acting beyond a pure service.

Processor. An organisation that processes personal data on a controller's instructions.

Special-category data. Particularly sensitive data, such as health, religion, trade-union membership or biometric data used to identify a person, with stricter rules.

Standard contractual clauses (SCCs). Approved contract terms that provide safeguards for transfers outside the EEA.

Sub-processor. A company engaged by a processor to help process the controller's data.

Transfer impact assessment. A documented review of whether a destination country's laws undermine the safeguards for a transfer.

Works council. An employee representative body that, in some countries, must be informed or consulted about technology that can monitor staff.

A Note on GDPRGard.eu

If your meeting-assistant work touches personal data, the free tools, guides and articles at **gdprgard.eu** can help with the surrounding tasks: records of processing, impact assessments, breach response and privacy notices. They are a companion resource, not a substitute for advice on your own situation.

About the Author

Zirlandia Milkovic writes practical, plain-English guides on data protection, cyber-security, AI and building a business with confidence. She believes technology should give small businesses and the people in them more control, not less, and that nobody should need a law degree or a technical background to understand their rights or protect their customers and colleagues.

She is the author of a series of business guides, including *GDPR Made Simple for Women Founders*, and her work focuses on turning complex rules and fast-moving technology into simple steps, checklists and templates that busy people can use on Monday morning. She is also behind **GDPRGard**, a growing collection of free GDPR tools, guides and articles for small businesses, available at gdprgard.eu.

The Meeting Bot Is in the Room grew out of a simple observation: AI notetakers arrive one employee at a time, and almost nobody decides on purpose to adopt them. If this guide helped you, an honest review where you bought it helps other readers find it.

Visit **gdprgard.eu** for free tools, articles and updates.

Notes and Sources

1. IAPP, "The second wave of AI governance: The risks of ubiquitous transcription tools" (author Noga Rosenthal), iapp.org. Described in the commissioning brief as published March 2026; the page's publication date could not be confirmed from the search result, and the full article was not read in this research.
2. Holland & Knight, "AI Meeting Assistants: Privacy, Security and Data Ownership Issues", 26 August 2026 (hklaw.com). Seen through a search summary: employee-monitoring concerns from speaking-time, speech-speed and sentiment analytics; state-level electronic-monitoring notice rules. The full text, including its GDPR and vendor-contract sections, was not read.
3. Brewer v. Otter.ai Inc., No. 5:25-cv-06911 (N.D. Cal., filed 15 August 2025). Proposed class action alleging a notetaker recorded non-user participants without consent, used recordings to train its models and did not explain its de-identification process. Allegations only; no findings by the court were seen, and current case status was not checked. Sources: NPR (15 August 2025), Fisher Phillips and other summaries; the complaint itself was not read.
4. Bloomberg Law, "AI Meeting Tools Pose Privacy Risks as Offices Boost Technology": argument that a vendor which listens and stores meeting content could be a third party under wiretap-type laws (seen through a search summary).
5. Duane Morris article on Mondaq, 6 March 2026, and related commentary, on privilege and confidentiality risks of AI transcription (seen through search summaries). Whether privilege is lost depends on jurisdiction and facts.
6. Regulation (EU) 2016/679 (GDPR), including Articles 5, 6, 9, 13-14, 17, 28, 30, 33-35 and Chapter V (44 onward) (working knowledge; read the text).
7. Reported position of German state authorities (LfDI Baden-Württemberg, BayLDA) on legitimate interests for summaries and live transcription versus consent for full transcripts, as described in vendor and law-firm blog posts. Not read in the authorities' own words; check your own regulator.
8. Regulation (EU) 2024/1689 (AI Act), Article 5(1)(f), emotion inference in the workplace and education (prohibitions applying from 2 February 2025), and the Commission's guidelines on prohibited practices. Seen through Future of Privacy Forum, Lewis Silkin and other secondary pieces; commentators differ on the biometric and "intention" edges. Article text not read directly.
9. EU-US Data Privacy Framework: General Court judgment in Latombe v Commission (T-553/23, 3 September 2025) dismissing the challenge; appeal lodged 31 October 2025 (C-703/25 P), reported pending as of late June 2026 (WilmerHale, Baker McKenzie and news summaries). Court of Justice docket not checked.

10. Platform behaviour (host enabling AI features, participant prompts, default retention) described in university IT help pages for a major video platform's AI assistant; defaults vary by plan and change often. Nothing was verified against a platform's own current documentation, and no information was found on the equivalent settings in other platforms.
11. Luxembourg CNPD guidance on recording meetings, referenced as dated 1 April 2026 in a law-firm article; only the title was seen.
12. State electronic-monitoring notice laws in the United States (Holland & Knight lists Connecticut, Delaware, New York, California, Illinois and Texas); not independently checked.
13. Article 29 Working Party, Opinion 2/2017 on data processing at work (WP 249), on proportionality, transparency and the limits of employee consent (working knowledge).
14. Data protection authorities' DPIA lists, and guidance treating systematic monitoring of employees as likely high-risk (working knowledge; check your national list).

Not verified by the author: the full text of the IAPP and Holland & Knight articles; the complaint, docket and current status of the Otter.ai case; the AI Act and GDPR texts and the Commission's guidelines; the regulators' own wording on legitimate interests and meeting recording; current admin settings, retention defaults and notification behaviour in any named platform; current vendor terms; the current status of the Latombe appeal; and each country's recording, works-council and employee-monitoring law. Vendor marketing claims, including a reported multi-million-euro fine over AI-transcribed meetings, could not be confirmed and are not relied on. Ines, Northlight Advisory, Tomás, Asel, Rhea, Kestrel Logistics, Brightwell Care and all events in the worked examples are fictional.